PASTA worksheet - Rayane Merlin

Stages	Sneaker company
I. Define business and security objectives	Make **2-3 notes** of specific business requirements that will be analyzed. ● *Will the app process transactions?* ● *Does it do a lot of back-end processing?* ● *Are there industry regulations that need to be considered?* The mobile app will process secure transactions along with offering several payment options Data privacy is a priority The app handles back-end processing for buyer/seller messaging and seller ratings
II. Define the technical scope	List of technologies used by the application: ● *Application programming interface (API)* ● *Public key infrastructure (PKI)* ● *SHA-256* ● *SQL* I would evaluate SQL prior because the app stores listings, seller information, and user data in a database that is queried regularly during critical actions (buying, selling). Poorly written and unprepared statements could allow SQL injection, exposing sensitive data. Since the product search process connects users directly to the database, it presents a large attack surface.
III. Decompose application	Look at the ***PASTA Dataflow Diagram*** There's the data flow : User searches for sneakers ⟶ The product search process queries the database ⟶Listings of current inventory are returned to the user.

	SQL, encryption, and hashing all protect data at these exchange points.
IV. Threat analysis	List **2 types of threats** in the PASTA worksheet that are risks to the information being handled by the application. ● *What are the internal threats?* ● *What are the external threats?* External threat : injection attacks by attackers sending malicious input through some fields to steal/alter data or elevate his privileges Internal threat : social engineering like phishing of an employee with database or admin access
V. Vulnerability analysis	List **2 vulnerabilities** in the PASTA worksheet that could be exploited. ● *Could there be things wrong with the codebase?* ● *Could there be weaknesses in the database?* ● *Could there be flaws in the network?* Lack of prepared statements in the codebase and database queries Weak or reused passwords, which allow session hijacking
VI. Attack modeling	Look at the **PASTA Attack Tree** The goal is to access user data every time. • First branch : Lack of prepared statements -> SQL Injection -> User data • Second branch : Weak login credentials -> Session hijacking -> User data
VII. Risk analysis and impact	List **4 security controls** that you've learned about that can reduce risk. - Prepared statements and input validation (for injection) - Multi-factor authentication (MFA) and password policies - Principle of least privilege - Encryption (PKI) with salted password hashing